

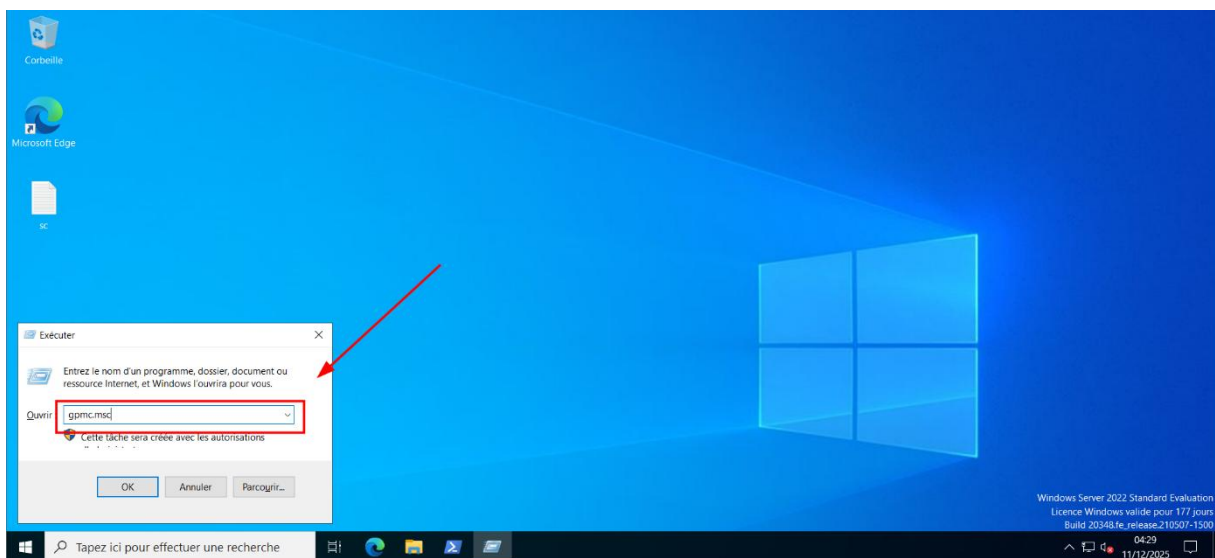
Partie 3 : Hardening du domaine Active Directory

Dans cette partie il sera question de sécuriser/durcir le domaine Active Directory configuré précédemment. Elle consiste essentiellement en le déploiement des GPOs de sécurité.

Trois politiques seront déployées :

- Password Policy
- Account Lockout Policy
- Security Options

Pour cela, il est nécessaire d'ouvrir l'outil de **Gestion des Stratégies de Groupe**. Taper simultanément Win + R puis entrer gpmmc.msc :



L'outil s'ouvrira.

Pour ne pas entrer en conflit avec le *Default Domain Policy* en créant d'autres Objets de stratégies certains paramètres y seront directement modifiés.

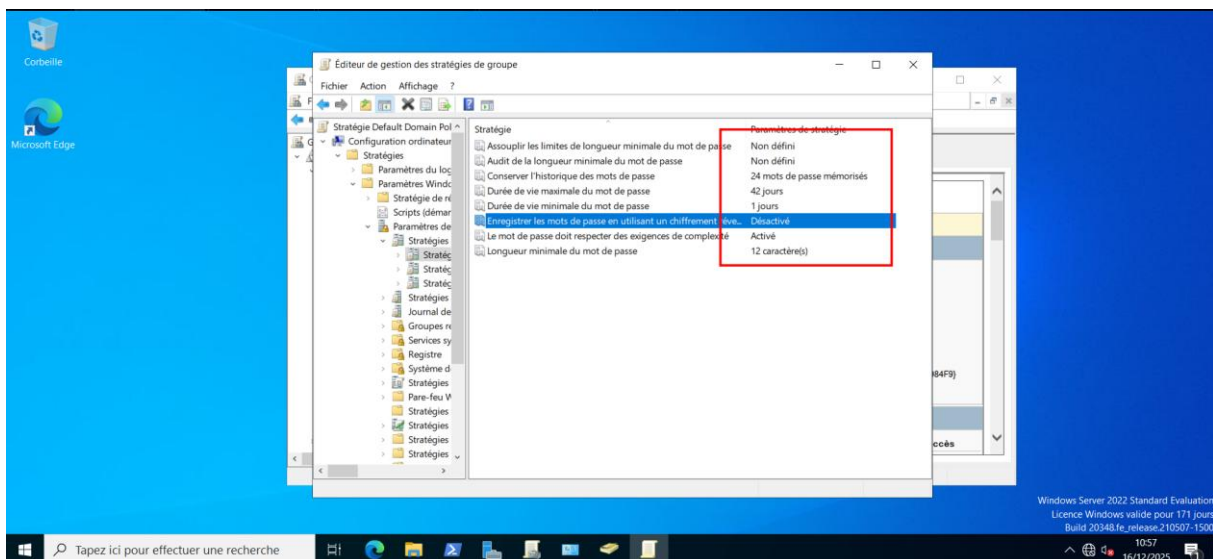
GPO 1 : Password Policy dans Default Domain Policy

Durant les tests de pénétrations effectués dans la partie précédente du LAB, nous avons pu constater une certaine faiblesse concernant les mots de passe des utilisateurs, plus précisément alicia qui avait un mot de passe de moins de 10 caractères (love@123).

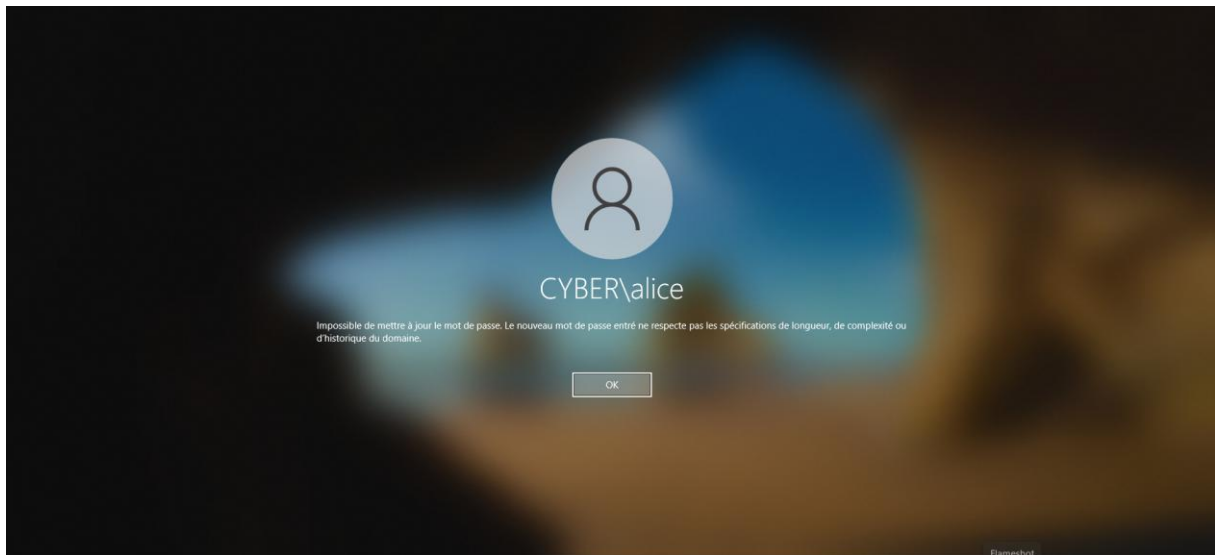
Pour réduire cette surface d'attaque, il est nécessaire de modifier la politique de mots de passe par défaut dans *Default Domain Policy*.

Nous allons la configurer en appliquant ces règles :

- **La durée maximale de vie des mots de passe à 42 jours** : obligeant l'utilisateur à changer de mots de passe tous les **2 mois**
- **La durée minimale de vie des mots de passe à 7 jours** : un mot de passe doit d'abord durer 1 mois avant d'être changé. Cela sert à prévenir des **changements fréquents** de mots de passe qui entraîneraient la **réutilisation d'anciens mots de passe**
- **La longueur minimale d'un mot de passe doit être de 12 caractères** : ce qui limite grandement les **attaques par dictionnaire**
- **Les mots de passe doivent respecter les exigences de complexité** : au moins 1 majuscule, 1 chiffre et 1 caractère spécial ; limitant les brute-force



Après application à distance depuis le DC, lorsque j'essaie de changer le mot de passe avec un mot de passe faible, j'obtiens une erreur :



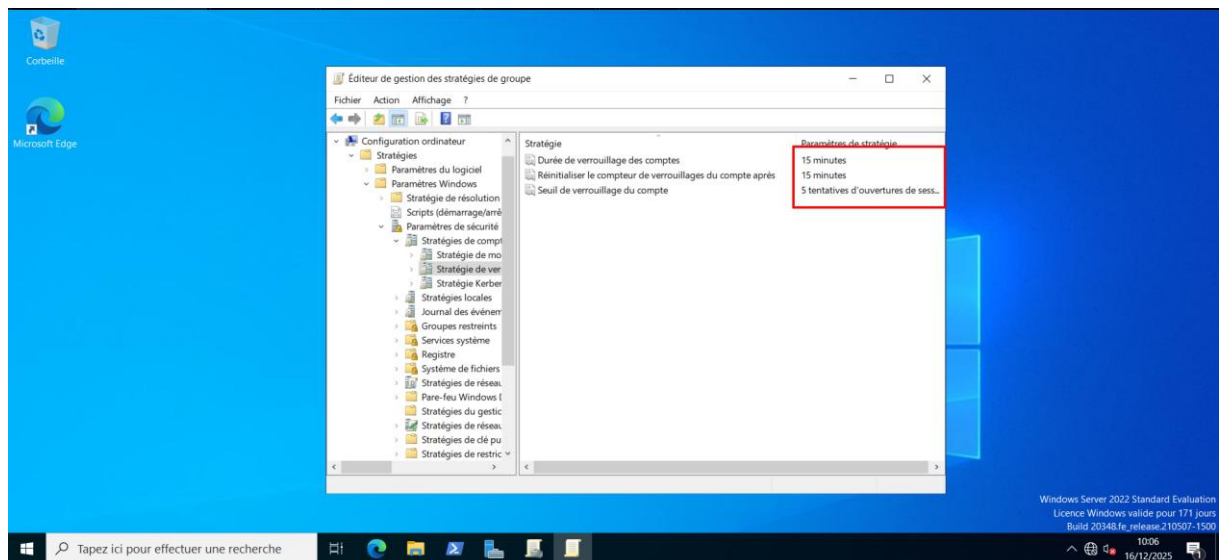
GPO 2: Account Lockout Policy dans Default Domain Policy

La réduction de la surface d'attaques liée aux mots de passe n'empêchent aucunement les tentatives de brute-force. Cela nous conduit à déployer une politique qui limite le nombre de tentatives d'authentification et qui verrouille le compte si le seuil est dépassé.

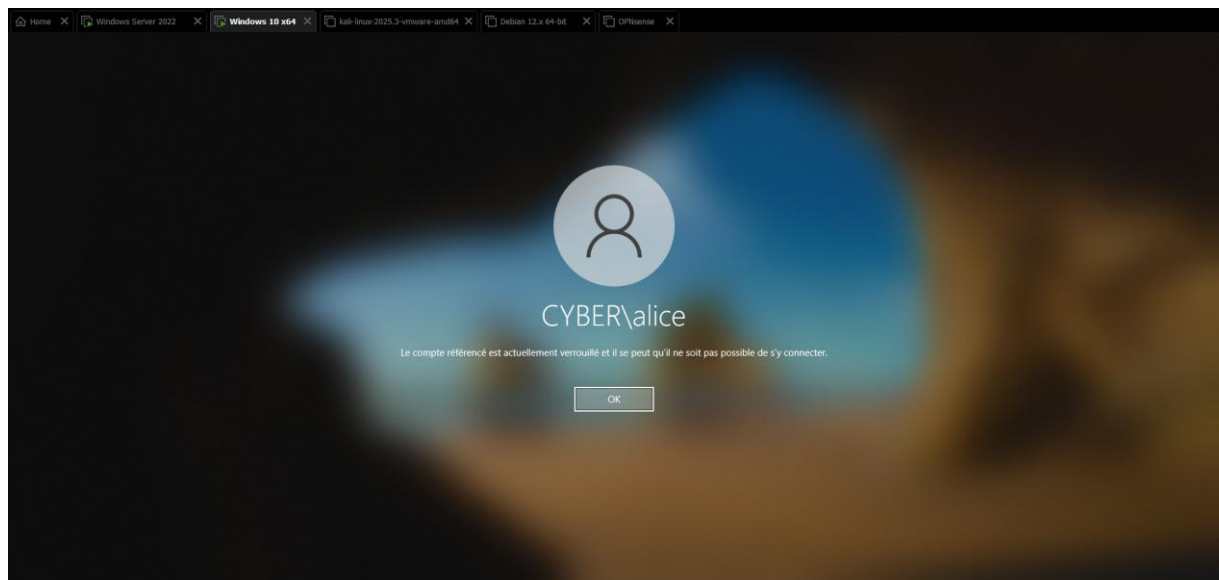
Une telle police pourrait favoriser un DDoS ayant pour but de verrouiller volontairement des comptes utilisateurs. De ce fait le verrouillage ne sera pas définitif, juste durant un certain temps. Nous allons éditer le *Default Domain Policy*.

La politique respectera les règles suivantes :

- Le seuil de verrouillage de compte limité à 5 tentatives
- La durée de verrouillage des comptes à 15 minutes
- La réinitialisation du compteur de verrouillage après 15 minutes



Mettons à jour les stratégies, déconnectons-nous et entrons des identifiants incorrects, le compte sera verrouillé :



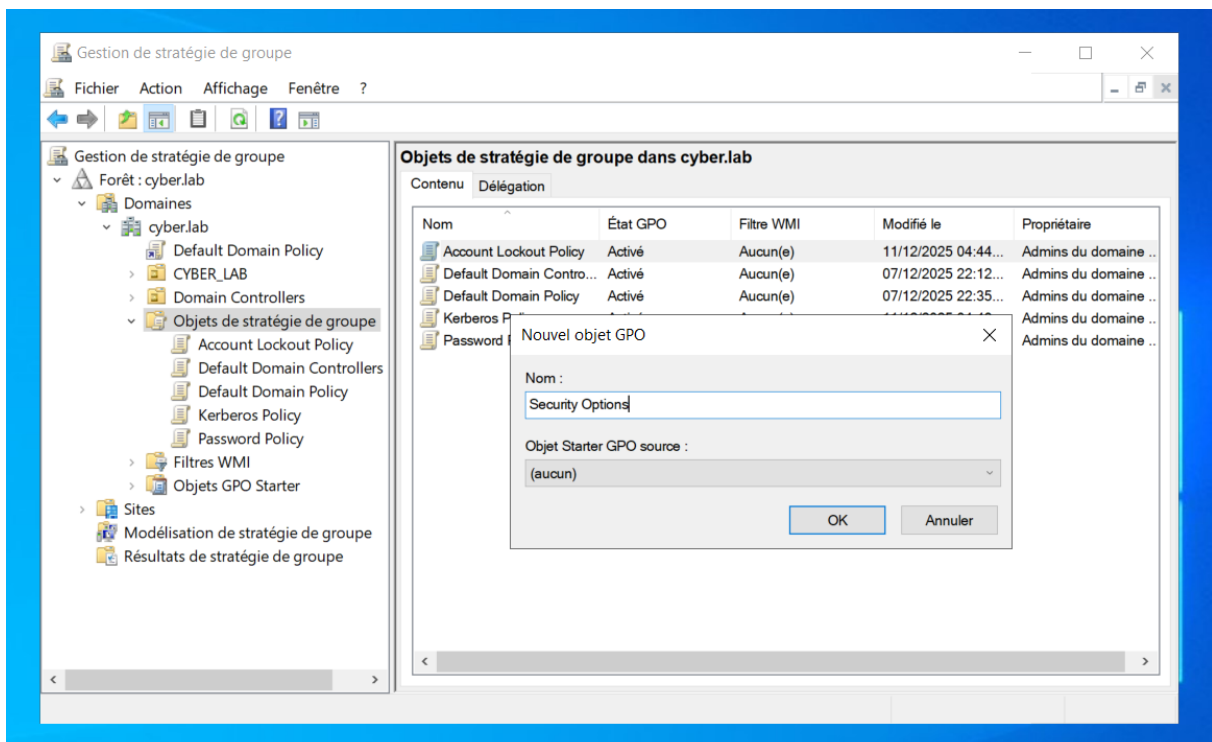
GPO 3: Security Options

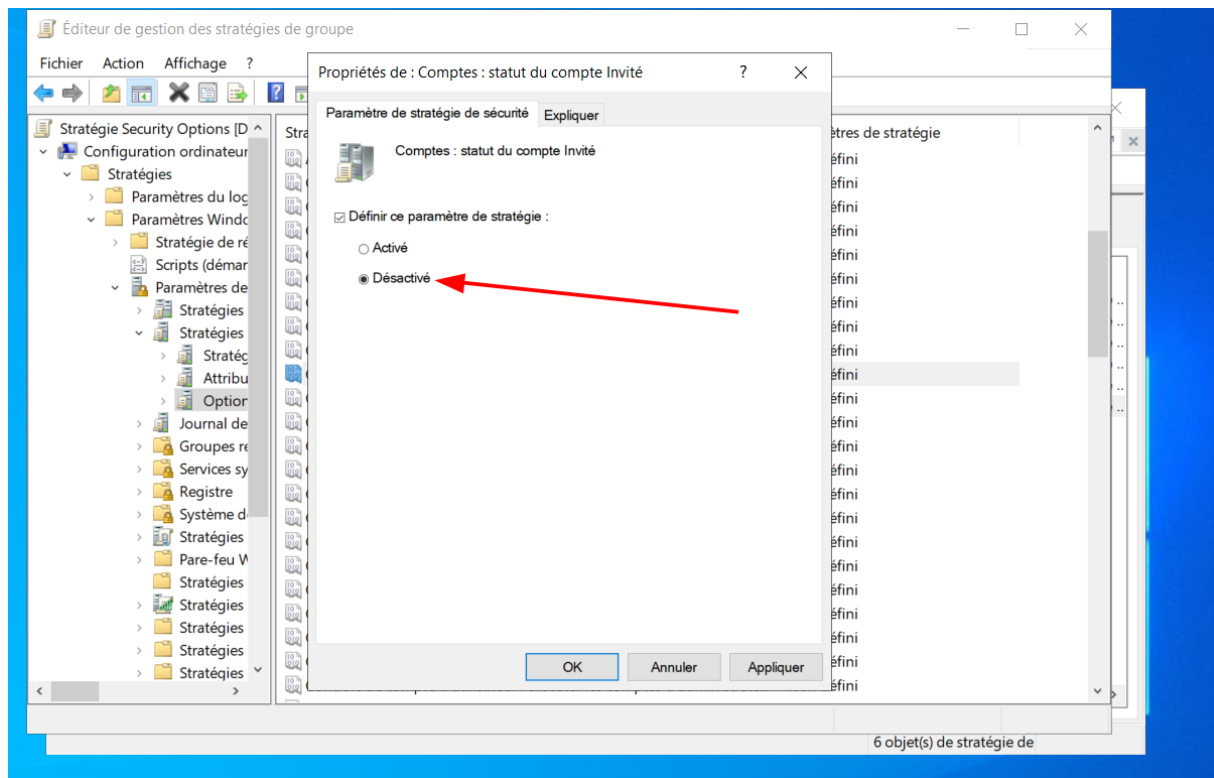
Dans un environnement Active Directory, surtout sur un **Domain Controller**, de nombreuses attaques ne passent pas par des exploits complexes mais par des **comportements Windows mal sécurisés** : authentification faible (LM/NTLMv1), stockage de hash vulnérable, accès anonymes, absence de signature LDAP/SMB ou divulgation d'informations à l'écran de connexion. Ces faiblesses permettent la

reconnaissance AD, le pass-the-hash, le NTLM relay, le MITM, voire une élévation de privilèges silencieuse, souvent sans déclencher d'alertes évidentes.

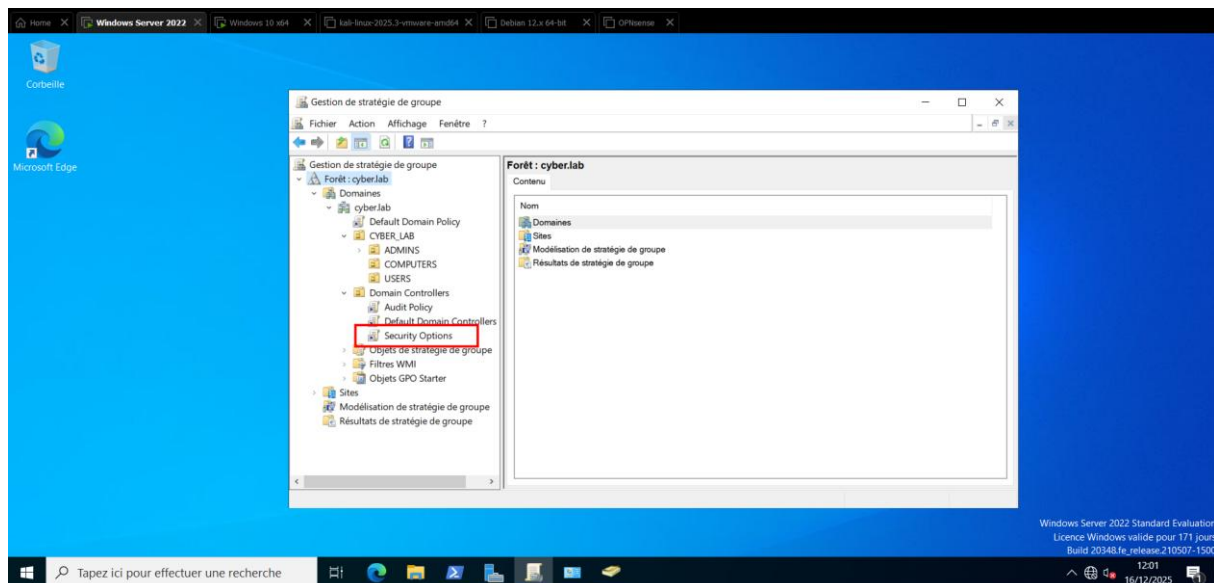
Pour y remédier, il est nécessaire de déployer une politique avec ces règles :

- Empêcher l'utilisation de méthodes de chiffrement faible (LM, NTLMv1)
- Désactiver le stockage de faibles hachages
- Désactiver le compte Invité





La politique **Security Options** sera liée à l'OU *Domain Controllers*



Sur le DC nous allons faire la mise à jour des stratégies et vérifier les stratégies appliquées :


```
PS C:\Users\Administrateur> gpupdate /force
Mise à jour de la stratégie...
```

La mise à jour de la stratégie d'ordinateur s'est terminée sans erreur.
La mise à jour de la stratégie utilisateur s'est terminée sans erreur.

```
PS C:\Users\Administrateur> gpreport /r

Outil de résultat du système d'exploitation Microsoft (R) Windows (R) v2.0
© Microsoft Corporation. Tous droits réservés.

Créé le 16/12/2025 à 12:05:28

Données RSOP pour CYBER\Administrateur sur DC1 : mode journalisation
-----
Configuration du système d'exploitation : Contrôleur principal de domaine
Version du système d'exploitation..... : 10.0.20348
Nom du site..... : Default-First-Site-Name
Profil itinérant : N/A
Profil local..... : C:\Users\Administrateur
Connexion via une liaison lente ? : Non

Paramètre de l'ordinateur
-----
CN=DC1,OU=Domain Controllers,DC=cyber,DC=lab
Heure de la dernière application de la stratégie de groupe : 16/12/2025 à 12:04:12
Stratégie de groupe appliquée depuis : DC1.cyber.lab
Seuil de liaison lente dans la stratégie de groupe : 500 kbps
Nom du domaine..... : CYBER
Type de domaine..... : Windows 2008 ou supérieur

Objets Stratégie de groupe appliqués
-----
  Default Domain Controllers Policy
  Audit Policy
  Security Options
  Default Domain Policy

Les objets stratégie de groupe n'ont pas été appliqués
car ils ont été refusés
-----
```

Conclusion globale

Ce projet a permis de mettre en place un environnement Active Directory représentatif d'un système d'information d'entreprise, depuis l'installation et la configuration du domaine jusqu'à l'intégration des postes et des utilisateurs. Les tests de pénétration réalisés ont démontré qu'un Active Directory fonctionnel mais configuré avec des paramètres par défaut reste fortement exposé : mots de passe faibles, absence de restrictions sur les tentatives d'authentification et mécanismes d'authentification hérités ont facilité l'énumération du domaine, la compromission d'un compte utilisateur, puis une escalade de privilèges menant à la prise de contrôle complète du Domain Controller.

La phase de **hardening** a permis de corriger ces faiblesses en s'appuyant sur des mécanismes natifs de Windows via les GPO : renforcement des politiques de mots de passe, verrouillage des comptes après plusieurs échecs et sécurisation des options système critiques. Ces mesures réduisent considérablement la surface d'attaque, compliquent les attaques par brute-force, le password spraying et les techniques de mouvement latéral basées sur NTLM. Ce LAB illustre ainsi l'importance d'une approche défensive complémentaire aux tests offensifs : **comprendre les attaques permet de déployer des contre-mesures efficaces**, indispensables pour assurer la sécurité et la résilience d'un domaine Active Directory en environnement professionnel.